Home Lab Project Week 11, Day 3
Task:
Analyze the firewall logs, Wireshark captures, scan results, and blocked/allowed traffic. Identify remaining weaknesses or configuration issues.

🔍 1. Firewall Log Analysis: Checking the Perimeters

Review your firewall's logs (e.g., pfSense `filter.log`, `iptables` logs) to find discrepancies between what you *thought* you blocked and what actually happened.

- **The "Any/Any" Trap:** Look closely at your rule base. Did you accidentally leave an outbound rule wide open? If your Metasploitable VM can still initiate outward connections to the internet or the attacker's subnet, an attacker could still leverage a **reverse shell** despite blocked inbound ports.
- **Implicit vs. Explicit Denies:** Ensure your firewall is ending with a clean "Default Deny" rule. If you see unhandled traffic passing through without matching a specific allow rule, your implicit rules are too permissive.
- **Protocol Mismatches:** Did you block TCP port 53 but leave UDP port 53 open? Check if your rules specify the correct protocol (`TCP`, `UDP`, or `TCP/UDP`).

🦈 2. Wireshark Capture Analysis: Reading Between the Lines

Open your `.pcap` files from yesterday's testing. Packet captures don't lie; they reveal exactly how your system reacted to the firewall rules.

- **REJECT vs. DROP Behavior:**
  - **DROP:** Look for TCP SYN packets from the attacker that receive **no response** (timeouts). This is ideal for stealth, as it gives the attacker no information.
  - **REJECT:** Look for `RST, ACK` (Reset) packets or `ICMP Destination Unreachable` messages sent back to the attacker. If your firewall is configured to `REJECT`, it actively tells the attacker "a firewall is blocking you here," confirming the presence of a security device.

- **Cleartext Leakage:** Analyze any allowed traffic (like HTTP on port 80). Are passwords, session tokens, or system command strings passing over the wire in plain text? If yes, the firewall may be blocking unauthorized access points, but the allowed lane is highly vulnerable to sniffing.
- **Evasion Techniques:** Check if basic scan packets using fragmented flags (e.g., Nmap `Fin`, `Null`, or `Xmas` scans) managed to slip past the firewall rules and generate responses from Metasploitable.

📊 3. Scan Results Analysis: Identifying App-Layer Blind Spots

Compare your Day 2 Nmap/Nessus results against your baseline.

- **The "Port 80/443" Dilemma:** If your firewall rules correctly allowed HTTP traffic so a legitimate user could access a web app, did Nmap or a vulnerability scanner still find **DVWA (Damn Vulnerable Web Application)** or **Mutillidae** flaws?
    - *The Weakness:* A standard network firewall cannot stop SQL Injection, Cross-Site Scripting (XSS), or Command Injection if port 80 is allowed. You have a **Layer 7 (Application Layer) vulnerability** that network rules alone cannot fix.
- **Filtered vs. Closed:**
    - If your scan shows ports as `closed` instead of `filtered`, the packets are hitting the Metasploitable OS loopback/kernel directly rather than being stopped by the firewall. This indicates the firewall rule isn't actually intercepting the traffic.

📝 4. Final Vulnerability Matrix (Deliverable Template)

Summarize your findings into this actionable matrix for your lab report:

Identified Weakness / Gap	Evidence Source (Log/PCAP/Scan)	Technical Root Cause	Risk Level (H/M/L)	Proposed Remediation

Example: Reverse Shells Allowed	*Wireshark PCAP*	Firewall allows all outbound traffic from Metasploitable to Attacker subnet on any port.	**High**	Restrict Metasploitable outbound rules to explicit ports (e.g., NTP/DNS only).
App-Layer Exploitation	*Nmap / Web Browser*	Network firewall allows Port 80 traffic; cannot inspect malicious payload strings (SQLi/XSS).	**High**	Deploy a Web Application Firewall (WAF) or patch the application source code.
Information Disclosure	*Firewall Logs (REJECT)*	Firewall rules use `REJECT` instead of `DROP`, mapping out active defenses for the attacker.	**Low**	Change firewall rule action from `REJECT` to `DROP`/`DENY`.